UNIVERSIDAD PRIVADA DE TACNA

FACULTAD DE INGENIERÍA

ESCUELA DE INGENIERÍA DE SISTEMAS

PROYECTO: "Diseño de una capa de publicación segura y de alta disponibilidad para la Universidad X"

Curso: SEGURIDAD DE TI

Docente: Dr. Renzo Alberto Taco Coayla

Integrantes:

Calizaya Ladera, Andy Michael	**(2022074258)**
Camac Melendez, Cesar Nikolas	**(2021072620)**
Castillo Mamani, Diego Fernando	**(2022073895)**
Colque Ponce, Sergio Alberto	**(2022073503)**
Ancco Suaña, Bruno Enrique	**(2023077472)**

Tacna – Perú

2026 - II

Diseño de una capa de publicación segura y de alta disponibilidad para la Universidad X

1 Resumen ejecutivo

El proyecto del curso Seguridad de TI diseña un laboratorio de cuatro máquinas virtuales (VM) para demostrar la protección de una aplicación web mediante un firewall de red, un firewall de aplicaciones web (WAF, *Web Application Firewall*) redundante, acceso administrativo restringido y recuperación de configuraciones. La Universidad X se conserva como contexto hipotético: el prototipo no despliega sus tres sistemas reales ni pretende atender a sus 8 400 usuarios.

Un solo equipo aloja OPNsense, dos proxies con Nginx, ModSecurity v3, el conjunto de reglas OWASP CRS (*Core Rule Set*) y keepalived, y una aplicación de laboratorio en contenedores. Se asignan 10 vCPU, 14 GB de RAM y 160 GB de disco a las VM. Las redes de zona desmilitarizada (DMZ) y de aplicación se separan mediante switches virtuales, con un segmento adicional para la administración del firewall; OPNsense controla los flujos entre ellas. Los registros locales y su exportación sustituyen al servidor exclusivo de monitoreo.

Las pruebas prioritarias comprueban el bloqueo de inyección SQL (SQLi) y de secuencias de comandos en sitios cruzados (XSS), la conservación del tráfico legítimo, la imposibilidad de acceder directamente al backend, HTTPS, la red privada virtual (VPN) con autenticación multifactor (MFA), la restauración y la continuidad del WAF al fallar un proxy. Se propone una conmutación ≤ 5 s y una diferencia de latencia p95 < 50 ms con 50 usuarios virtuales, umbrales que se medirán en la Unidad III. La literatura revisada orienta la evaluación y advierte sobre fallas funcionales de los proxies y sobre falsos positivos de las reglas.

El plan comprende cuatro semanas y catorce casos de prueba. El escenario reutiliza un equipo y estima S/ 3 740,00 de inversión inicial, incluido el trabajo valorizado y una reserva del 10 %. El costo total de propiedad (TCO) de un ciclo de cuatro semanas es S/ 4 289,60; ambos importes son supuestos de planificación. El equipo físico, el firewall y la aplicación no son redundantes: el diseño demuestra la disponibilidad de la capa proxy ante fallas de VM o de servicio, no la continuidad integral del servicio institucional.

Palabras clave: seguridad de TI, WAF, segmentación, alta disponibilidad del proxy, laboratorio.

2 Planteamiento del problema

2.1 Contexto y línea base

La Universidad X representa una institución privada mediana con 8 000 estudiantes y 400 docentes y administrativos. Sus tres aplicaciones sostienen consultas, actividades de aprendizaje y trámites de matrícula. Se supone que cada aplicación se publica desde un servidor sin una política WAF común, sin segmentación formal y sin redundancia de publicación. El contexto motiva un prototipo acotado a una aplicación de laboratorio; Moodle y los sistemas institucionales quedan fuera de la instalación y de la validación.

Para caracterizar el tráfico de evaluación del WAF se adoptó el conjunto de datos HTTP CSIC 2010 (Torrano-Giménez et al., 2010; Spangler, 2019), generado por el Instituto de Seguridad de la Información del CSIC contra una aplicación de comercio electrónico. El conjunto contiene 61 065 solicitudes HTTP: 36 000 legítimas (58,9 %) y 25 065 anómalas (41,1 %). Las solicitudes legítimas cubren navegación, inicio de sesión, búsqueda, formularios con caracteres acentuados y cookies (28 000 GET y 8 000 POST); las anómalas incluyen inyección SQL (SQLi), secuencias de comandos en sitios cruzados (XSS), inclusión del lado del servidor (SSI), recorrido de directorios, desbordamiento de búfer y manipulación de parámetros (15 088 GET, 9 580 POST y 397 PUT). De las 25 065 solicitudes anómalas enviadas sin WAF, todas obtuvieron respuesta del servidor. El recuento por código de estado y categoría se adjuntará como evidencia; una respuesta HTTP no equivale por sí sola a una explotación exitosa, pero muestra que la aplicación no filtró ninguna solicitud. Estas cifras cuantifican la exposición que el diseño debe reducir.

La Tabla 1 separa el contexto académico de la implementación y resume la línea base medida. La carga de 50 usuarios virtuales permite una evaluación inicial acotada y no procede de un estudio de demanda. Un estudio educativo sobre balanceo de carga motiva comparar configuraciones, aunque sus resultados no sirven para dimensionar este laboratorio (Han y Ye, 2023).

Tabla 1

Contexto, alcance y línea base del laboratorio

Variable	Valor	Naturaleza
Contexto institucional	Universidad X y sus 8 400 usuarios	Hipotético; no se despliega a esa escala
Aplicación implementada	Una aplicación de laboratorio con datos sintéticos	Backend único en contenedores
Línea base experimental	Misma aplicación sin WAF, solo en red aislada	Comparación controlada
Solicitudes anómalas con respuesta del servidor sin WAF (CSIC 2010)	25 065 de 25 065 solicitudes (100 %) con respuesta HTTP; recuento por código y categoría por adjuntar	Conjunto CSIC 2010 (Torrano-Giménez et al., 2010)
Latencia p95 sin WAF (50 usuarios)	Pendiente de medición en laboratorio	Se medirá con solicitudes del conjunto CSIC 2010
Concurrencia	50 usuarios virtuales; explorar 10 y 100	Meta de laboratorio por verificar
Infraestructura	Un equipo físico, cuatro VM y tres redes internas	Reutilización condicionada a inventario
Disponibilidad	Conmutación entre proxies; ensayo de 30 min	Mide la sesión observada, no la disponibilidad anual

Nota. Elaboración propia. Las filas resaltadas corresponden al prototipo mínimo descrito en esta sección; su evidencia se encuentra en la carpeta indicada en la sección 10.3.

2.2 Evidencia y necesidad

Godinho et al. (2023) describen un ataque durante un examen en Moodle que produjo aproximadamente 800 Mbps de tráfico frente a los 30–50 Mbps habituales y afectó elementos compartidos de la infraestructura. El proxy HAProxy principal permaneció activo sin prestar adecuadamente el servicio, por lo que la comprobación basada en la presencia del proceso

no provocó la recuperación esperada. Este antecedente justifica que la salud de Nginx se compruebe por su respuesta funcional y no solo por la presencia del proceso, criterio que se validará en PT-04b.

El principal riesgo operativo de un WAF en modo de bloqueo es rechazar tráfico legítimo. Los estudios sobre detectores basados en firmas y sobre niveles de paranoia de CRS muestran que la configuración predeterminada no equilibra por sí sola detección y precisión (Díaz-Verdejo et al., 2022; Reyes Narváez et al., 2025; Reyes Narváez et al., 2026). Por ello el proyecto parte del nivel PL1, mide los falsos positivos con tráfico legítimo representativo y repite las pruebas tras cada excepción.

Los trabajos con aprendizaje automático (LSTM, detección de anomalías, transformadores sobre URL y clasificadores por partes de HTTP) usaron conjuntos de datos distintos, por lo que no permiten fijar una tasa de detección esperada para ModSecurity (Dawadi et al., 2023; Demirel y Sandikkaya, 2023; Deshpande y Singh, 2024; Shaheed y Kurdy, 2022). De ellos se adopta un solo criterio: evaluar con entradas variadas y reportar resultados por clase de ataque. No se incorporan como componentes.

Los trabajos de clasificación multietiqueta, normalización de SQLi/XSS y perfilado del atacante muestran que una exactitud global puede ocultar diferencias entre tipos de ataque (Chindrus y Caruntu, 2025; Shahid et al., 2022; Tadhani et al., 2024). Por eso se conservará una matriz de confusión por categoría y casos en URL, cabeceras, cookies y cuerpos.

Los estudios de evasión con aprendizaje por refuerzo, ejemplos adversariales y mutación de cargas indican que un repertorio fijo deja cobertura sin evaluar (Guan et al., 2023; Hemmati y Hadavi, 2022; Qu et al., 2024; Wu et al., 2025). Por eso se usarán un conjunto de regresión y otro de evaluación separado, con variantes etiquetadas, ejecutadas solo en el laboratorio autorizado y sin dirigir ataques a servicios externos.

2.3 Formulación y justificación

La pregunta del proyecto es: ¿cómo diseñar una capa de publicación que inspeccione las solicitudes de una aplicación de laboratorio, conserve el acceso legítimo y recupere el servicio ante fallas del proxy con criterios medibles? La respuesta propuesta une controles de HTTP, redundancia, observabilidad y procedimientos de operación. La separación entre aplicaciones y seguridad tiene antecedentes en servicios de protección basados en proxy, aunque las capacidades de cada propuesta difieren (Fujii et al., 2025).

Brecha de investigación aplicada. En el conjunto de antecedentes utilizado, los trabajos sobre falsos positivos y niveles de paranoia aportan criterios para evaluar reglas WAF, y los estudios sobre balanceo y fallas de publicación aportan criterios de continuidad. Estas contribuciones justifican componentes individuales, pero no proporcionan la validación conjunta del laboratorio aquí delimitado: cuatro VM que integran Nginx y CRS, conmutación mediante keepalived, segmentación con OPNsense y acceso administrativo por VPN con MFA (Godinho et al., 2023; Ma y Chi, 2022; Reyes Narváez et al., 2025; Reyes Narváez et al., 2026). La brecha identificada es la falta de evidencia integrada y trazable para esta configuración y estas restricciones académicas.

Aporte del proyecto. Se propone cubrir esa brecha mediante una especificación reproducible que relaciona versiones, configuraciones, requerimientos y catorce pruebas. La evaluación combinará falsos positivos y detección de SQLi/XSS con acceso directo denegado, restauración y continuidad de la inspección después de una conmutación. La contribución es de integración y validación aplicada: documentar en un mismo escenario cómo interactúan protección, tráfico legítimo y recuperación, con configuraciones y evidencias que permitan reproducirlo.

3 Objetivos

3.1 Objetivo general

Diseñar un laboratorio de seguridad web de cuatro máquinas virtuales que integre segmentación con OPNsense, inspección con Nginx, ModSecurity y OWASP CRS, acceso administrativo por VPN con MFA y redundancia con keepalived, estableciendo pruebas de protección, recuperación y conmutación ≤ 5 s sin desactivar el WAF.

3.2 Objetivos específicos

La Tabla 2 vincula cada objetivo con un producto verificable. Los objetivos de diseño se desarrollan en la Unidad II; la ejecución y la evidencia de los componentes se completan en la Unidad III. En OE4, el objetivo de punto de recuperación (RPO) expresa la pérdida máxima de datos admitida y el objetivo de tiempo de recuperación (RTO), el tiempo máximo para restablecer el servicio.

Tabla 2

Objetivos y criterios de cierre

Código	Objetivo	Evidencia de cumplimiento
OE1	Fundamentar el problema y las decisiones con la Unidad I	≥ 40 fuentes distintas citadas y correspondencia bibliográfica
OE2	Especificar funciones y atributos medibles	6 RF y 9 RNF con componente y prueba
OE3	Diseñar arquitectura, infraestructura y red	4 diagramas; recursos, IP y comunicaciones consistentes
OE4	Definir seguridad y recuperación	9 riesgos; controles, accesos, RPO y RTO
OE5	Planificar operación, implementación y costos	RACI, procedimientos, 4 semanas y TCO del ciclo académico
OE6	Diseñar la validación del laboratorio	14 pruebas especificadas con registros y criterios reproducibles

Nota. Elaboración propia. La ejecución de las pruebas y sus resultados corresponden a la Unidad III.

4 Requerimientos

4.1 Requerimientos funcionales

La Tabla 3 concentra las funciones de publicación y administración. Los identificadores RF se mantienen en el plan de pruebas y en las evidencias. En ella, TLS (*Transport Layer Security*)

cifra el tráfico entre el cliente y el proxy, la dirección IP virtual (VIP) es la que comparten los dos proxies y RBAC designa el control de acceso basado en roles.

Tabla 3

Funciones de publicación y administración

ID	Función y aceptación	Componente y prueba
RF-01	Publicar 1 aplicación por HTTPS; nombre local resuelto al acceso externo del firewall, TLS 1.2/1.3 y acceso externo directo a backends bloqueado	Nginx, firewall; PT-01
RF-02	Inspeccionar las rutas públicas; documentar contenidos, límites de cuerpo y exclusiones; motor en bloqueo	ModSecurity y CRS; PT-02/03
RF-03	Migrar la VIP automáticamente al caer el nodo o al dejar de responder Nginx	keepalived y salud funcional; PT-04/04b
RF-04	Correlacionar cada bloqueo con el registro local del proxy que lo atendió: fecha, aplicación, regla e identificador	ModSecurity y exportación de evidencias; PT-07
RF-05	Aplicar límites configurables; el exceso de tasa recibe 429 y las conexiones lentas expiran; un cliente legítimo independiente conserva el acceso	Nginx; PT-08
RF-06	Administrar solo desde la VPN o un segmento autorizado, con MFA y permisos por rol (RBAC); denegar la administración desde la WAN	VPN, firewall y RBAC; PT-10

Nota. Elaboración propia. Una respuesta 403 se considera bloqueo del WAF solo si existe su registro de auditoría correlacionado.

4.2 Requerimientos no funcionales

La Tabla 4 establece los umbrales elegidos por el proyecto para cada atributo exigido. CRS se configurará en el nivel de paranoia 1 (PL1); el nivel 2 (PL2) es experimental y solo sustituirá a PL1 si cumple también los límites de latencia y de falsos positivos (FP). La comparación entre configuraciones considera simultáneamente detección, tráfico legítimo y desempeño (Durmuşkaya y Bayraklı, 2025; Reyes Narváez et al., 2025).

Tabla 4

Atributos y criterios de aceptación

ID	Atributo	Criterio	Prueba
RNF-01	Disponibilidad	Ensayo de 30 min con dos conmutaciones: caída acumulada ≤ 10 s	PT-05
RNF-02	Disponibilidad	Conmutación ≤ 5 s por repetición ante falla de nodo y de servicio	PT-04/04b
RNF-03	Rendimiento	p95 con WAF menos p95 sin WAF < 50 ms a 50 usuarios virtuales	PT-06
RNF-04	Seguridad	PL1: detección ≥ 90 %, FP ≤ 2 %; PL2: meta ≥ 95 % y reporte de FP y latencia	PT-02/03
RNF-05	Rendimiento	Solicitudes legítimas fallidas ≤ 1 % a 50 usuarios	PT-06
RNF-06	Mantenibilidad	Validación, versión y reversión; cero fallas legítimas atribuibles a una recarga controlada	PT-09
RNF-07	Seguridad (auditoría)	Cada bloqueo muestra un identificador; el analista encuentra el evento local y su copia exportada en ≤ 5 min	PT-07

ID	Atributo	Criterio	Prueba
RNF-08	Escalabilidad	A 100 usuarios virtuales, solicitudes legítimas fallidas ≤ 2 % y registro del punto de saturación; la DMZ /24 admite un tercer proxy sin cambiar el direccionamiento	PT-06
RNF-09	Usabilidad	La página de bloqueo 403 muestra un mensaje comprensible y el identificador del evento, sin revelar la regla ni datos internos	PT-07

Nota. Elaboración propia. FP: falsos positivos; p95: percentil 95; PL: nivel de paranoia de CRS.

La detección se calcula como las solicitudes maliciosas bloqueadas divididas entre las maliciosas válidas, y los FP como las legítimas bloqueadas divididas entre las legítimas válidas. La tasa de error incluye respuestas inesperadas, tiempos agotados y respuestas 429 a tráfico legítimo. El tiempo de conmutación se mide desde la inducción del fallo hasta obtener respuestas estables del respaldo. La diferencia de percentiles compara dos distribuciones de latencia y no equivale al tiempo individual de ejecución de ModSecurity.

Cada requerimiento tendrá estado pendiente, cumplido, parcial o no cumplido, con enlace a configuración, prueba y evidencia. Solo una ejecución documentada puede cambiarlo a cumplido. Las mediciones conservarán la misma mezcla de tráfico, recursos, duración y versiones, y comprobarán que el generador no limita el ensayo.

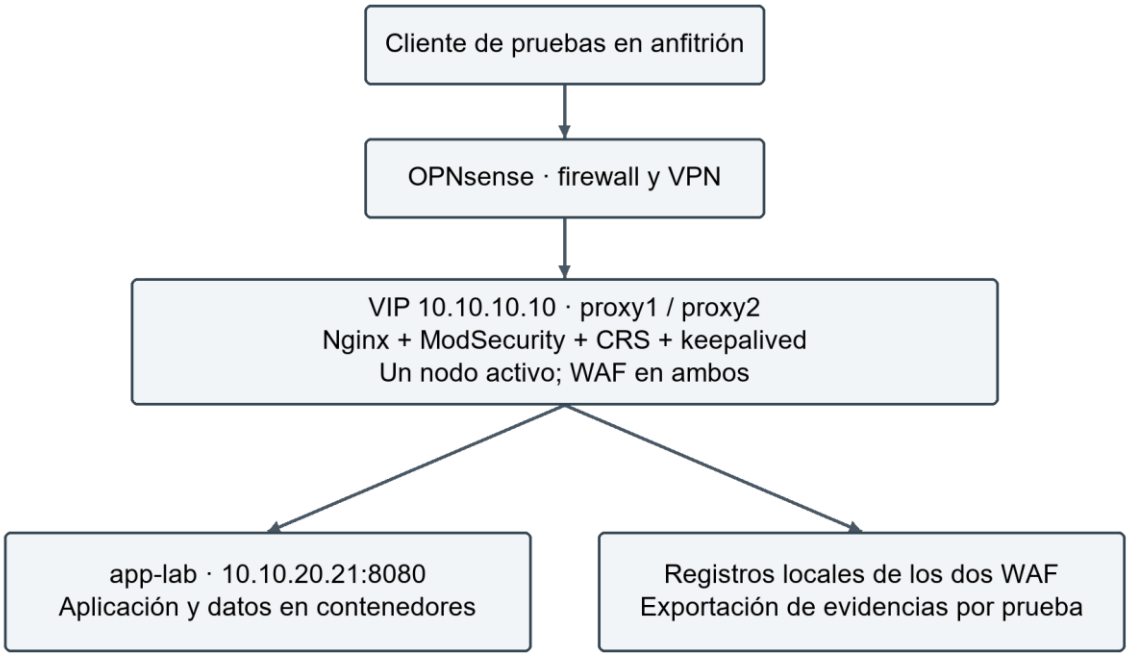
5 Diseño de la arquitectura

5.1 Componentes y flujo

La Figura 1 presenta el flujo desde un cliente de pruebas situado en el segmento externo del laboratorio. OPNsense permite HTTPS hacia la VIP; Nginx termina TLS y entrega las solicitudes al motor ModSecurity con CRS. Las aceptadas llegan al puerto 8080 del backend. La aplicación y su base de datos, si la requiere, comparten VM mediante contenedores; la base de datos no publica puertos en el host ni en otras redes.

Figura 1

Arquitectura lógica de protección web



Nota. Elaboración propia. Un solo proxy atiende la VIP; ambos mantienen el WAF activo y registran sus propias solicitudes.

Se usará OWASP Juice Shop, una aplicación intencionalmente vulnerable en contenedor, limitada al laboratorio y con datos sintéticos, para comparar casos SQLi/XSS y tráfico legítimo. La imagen y sus dependencias se fijarán por versión o *digest*. Tendrá una sola interfaz en la red de aplicaciones, sin modo de red del host, y el router de Internet no tendrá puertos abiertos hacia el laboratorio.

Ambos proxies tendrán configuración, certificados y excepciones equivalentes. Git conservará los archivos sin secretos; la copia controlada por SSH con comparación de *hashes* permite empezar sin Ansible. Las claves privadas y las copias con secretos estarán cifradas fuera del repositorio. Cada ensayo exportará los registros de ambos nodos y del firewall a una carpeta de evidencias, lo que evita un colector permanente.

5.2 Conmutación y límites

Keepalived mantiene la VIP 10.10.10.10 entre proxy1 y proxy2 mediante el protocolo VRRP (*Virtual Router Redundancy Protocol*). Se propone un anuncio VRRP por segundo, enviado por unidifusión entre 10.10.10.11 y 10.10.10.12 (unicast_peer) para no depender del tratamiento de la multidifusión en las redes internas del hipervisor. La comprobación local se ejecutará cada segundo, con tiempo máximo de un segundo, sobre http://127.0.0.1:8081/healthz, implementada en un *listener* de Nginx accesible solo por loopback. El script verificará respuesta y contenido esperado, con dos fallos consecutivos para retirar la elegibilidad y tres éxitos para la recuperación. Estos parámetros son iniciales; PT-04 y PT-04b confirmarán el umbral de cinco segundos bajo carga y documentarán los ajustes.

PT-04 comparará el apagado ordenado, que emite un anuncio con prioridad 0 y acelera el relevo, con el corte abrupto de la VM, que depende del tiempo de espera de tres anuncios.

La comprobación local evita cambiar de proxy por una falla común del backend, y los sondeos externos complementarios detectarán problemas de publicación completa. Se ensayarán el corte del nodo y la detención y el congelamiento del servicio, distinguiendo la salud del proceso de la salud funcional. El trabajo sobre Nginx y keepalived respalda estudiar ambos componentes, mientras que los tiempos de recuperación de este laboratorio se obtendrán de sus propias pruebas (Godinho et al., 2023; Ma y Chi, 2022).

La conmutación no replica conexiones TCP ni datos de la aplicación, de modo que una operación interrumpida puede requerir un reintento seguro. Las cuatro VM comparten un solo equipo: si este se apaga, todas se pierden temporalmente. El firewall y la aplicación también son puntos únicos de falla. El objetivo medible se limita a mantener la protección ante la caída de un proxy o de su servicio.

5.3 Alternativas y criterio de selección

Se mantiene Nginx con ModSecurity por continuidad del proyecto y por permitir una inspección explícita; HAProxy sigue siendo una alternativa válida. Coraza con Caddy o Envoy ofrece otro entorno de evaluación, pero sus resultados de falsos positivos no se trasladan automáticamente al conector de Nginx. Un WAF basado en redes definidas por software (SDN) añade dependencia de un controlador, mientras que el diseño actual conserva separados el plano de red y la inspección HTTP (Alotaibi y Vassilakis, 2023; Curipallo Martínez et al., 2025).

PROGESI propone gramáticas como capa intermedia frente a SQLi, y ModSec-AdvLearn estudia la selección y ponderación de reglas con aprendizaje adversarial. Son alternativas de mejora que requieren entrenamiento, mantenimiento y validación adicionales. Se priorizan las reglas CRS y las exclusiones revisables, dejando esas extensiones fuera del despliegue inicial (Coscia et al., 2024; Floris et al., 2025).

El proxy tampoco cubre automáticamente toda amenaza del lado del cliente: NAISS utiliza firmas de imágenes contra *e-skimmers* en comercio electrónico, una función distinta a inspeccionar entradas con CRS. La arquitectura de virtualización de funciones de red (NFV) de Mauricio y Rubinstein incorpora encadenamiento y reglas dinámicas; se toma como antecedente de separación funcional y de costo de reglas (Mauricio y Rubinstein, 2023; Rus et al., 2024).

6 Diseño de infraestructura

6.1 Dimensionamiento y despliegue

La Tabla 5 reduce el despliegue a cuatro VM. La asignación es inicial y se comprobará durante las pruebas, ya que el consumo observado en otras tecnologías no permite dimensionar directamente este WAF (de Oliveira et al., 2025). Se conservará una sola aplicación para concentrar el esfuerzo en los controles de seguridad.

Tabla 5

Asignación de máquinas virtuales del laboratorio

VM	Host	vCPU	RAM GB	Disco GB	Función
firewall	Equipo local	2	4	20	OPNsense, segmentación y VPN
proxy1	Equipo local	2	3	30	Nginx, ModSecurity, CRS y keepalived
proxy2	Equipo local	2	3	30	Mismos controles; respaldo de la VIP
app-lab	Equipo local	4	4	80	Aplicación y datos sintéticos en contenedores
Total	1 equipo	10	14	160	4 VM

Nota. Elaboración propia. Las vCPU son asignaciones virtuales que comparten los núcleos físicos del anfitrión.

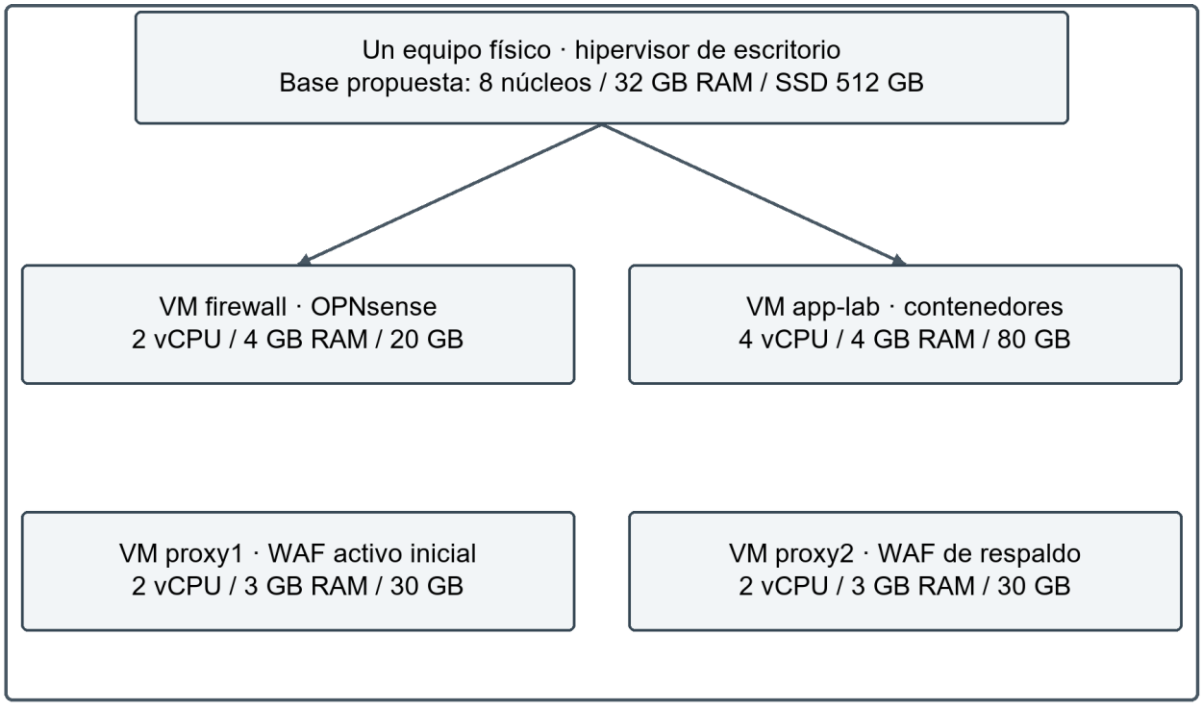
Se propone reutilizar un equipo con virtualización habilitada, ocho núcleos físicos, 32 GB de RAM y SSD de 512 GB o más, con al menos 220 GB libres para discos virtuales, instantáneas temporales y exportaciones. Esta especificación es una base de planificación que se confirmará con el inventario. El sistema anfitrión y el cliente de pruebas necesitan recursos adicionales a los 14 GB asignados a las VM. Si el inventario no alcanza esta base, se ajustará la carga tras medir, sin eliminar el firewall ni el segundo WAF.

El hipervisor de escritorio será VirtualBox, sujeto a comprobar su compatibilidad con el sistema anfitrión. Las tres redes internas se configurarán como redes internas aisladas, sin adaptadores del anfitrión. Solo la WAN de OPNsense usará una red de solo anfitrión para comunicar el cliente ejecutado en el equipo físico; esta WAN simulada no es Internet. La VM firewall tendrá cinco adaptadores (WAN, DMZ, aplicaciones, gestión y el adaptador NAT temporal de mantenimiento); los que excedan los cuatro de la interfaz gráfica se configurarán con VBoxManage. El diseño no requiere switch administrable, NAS, LACP ni un segundo servidor.

La Figura 2 muestra la distribución de las cuatro VM en el equipo físico y los recursos asignados a cada una.

Figura 2

Despliegue en un equipo físico



Nota. Elaboración propia. El cliente de pruebas y las copias externas se ejecutan fuera de las VM; el anfitrión debe conservar recursos libres y aislamiento verificado.

6.2 Software y almacenamiento

La Tabla 6 fija la línea base de software del diseño. Las versiones provienen de publicaciones oficiales vigentes a noviembre de 2026, y su compatibilidad conjunta se confirmará durante la instalación. Se seleccionan versiones concretas para que la instalación y las mediciones puedan reproducirse. Si un aviso de seguridad o una incompatibilidad exige cambiar una versión, se actualizarán esta tabla y el manifiesto antes de ejecutar las pruebas.

Tabla 6

Versiones de referencia y control de instalación

Componente	Versión propuesta	Ubicación y control de reproducibilidad
Oracle VirtualBox	7.2.6	Anfitrión; registrar versión y revisión del instalador (Oracle, s. f.).
Ubuntu Server LTS	24.04.5 amd64	proxy1, proxy2 y app-lab; verificar SHA-256 de la ISO y registrar paquetes tras aplicar actualizaciones de seguridad (Canonical, 2026).
OPNsense CE	26.7.8	VM firewall; registrar revisión y hotfix exactos, exportación de configuración y paquetes incluidos (OPNsense, 2026).
Nginx	1.30.6	Ambos proxies; misma versión, opciones de compilación y configuración (NGINX, s. f.).
libModSecurity	3.0.16	Ambos proxies; fijar etiqueta de origen y hash del código compilado (OWASP ModSecurity Project, 2026).
Conector ModSecurity-nginx	1.0.4	Compilar para la misma versión y opciones de Nginx; verificar la carga del módulo (OWASP ModSecurity Project, 2025).

Componente	Versión propuesta	Ubicación y control de reproducibilidad
OWASP CRS	4.30.0	Mismo conjunto de reglas y exclusiones en ambos proxies; PL1 inicial, PL2 experimental (OWASP CRS Project, 2026).
Keepalived	2.4.3	Ambos proxies; registrar versión, configuración VRRP y script de salud (Keepalived, 2026).
Docker Engine	29.9.3	app-lab; rama con soporte vigente; registrar versión del motor y dependencias; sin publicación de puertos de base de datos (Docker, 2026).
OWASP Juice Shop	20.4.0	Aplicación vulnerable aislada; fijar etiqueta y digest de la imagen; publicar 8080 de app-lab hacia 3000 del contenedor (OWASP Juice Shop Project, 2026).

Nota. Elaboración propia a partir de las publicaciones citadas. Ubuntu conservará los parches de seguridad de su rama y OPNsense incorporará los hotfix necesarios, con sus identificadores registrados. La evidencia final usará etiquetas de versión fijas en lugar de *latest*.

El servicio VPN será el OpenVPN incluido en OPNsense, sin instalar otra pila VPN. OpenSSL, OpenSSH, el runtime de contenedores y las dependencias de la aplicación conservarán las versiones suministradas por sus respectivos paquetes o imágenes, que se exportarán al manifiesto de instalación junto con la versión de cada producto principal.

Antes de congelar la línea base se ejecutará nginx -t, se comprobará la carga del conector y se reproducirá un bloqueo CRS con su registro. Después se probarán el tráfico legítimo, la VPN con MFA, el aislamiento y la conmutación con el WAF activo. Ambos proxies deberán coincidir en versiones y *hashes* de reglas. La evidencia incluirá nginx -V, keepalived --version, docker version, la identificación de OPNsense y el digest de Juice Shop. La compatibilidad efectiva se establece con esta validación.

Las actualizaciones se descargarán en una ventana controlada mediante una conexión temporal del firewall hacia una red NAT del hipervisor, que se desconectará antes de los ensayos. Ni app-lab ni los proxies tendrán un adaptador NAT propio. La consola local del hipervisor se reserva para instalación y recuperación; el acceso remoto habitual pasará por la VPN.

Esta versión prescinde de Wazuh, Prometheus y Grafana. Se registrarán CPU, RAM, espacio y tiempos HTTP con herramientas del sistema y del cliente. El antecedente de envejecimiento de software motiva observar el consumo durante una sesión prolongada, aunque aquí no se emplea Kubernetes (Costa et al., 2023).

Cada proxy reservará hasta 5 GB para registros con rotación, y la prueba se detendrá si queda menos del 20 % de espacio libre. La retención inicial será de siete días o el límite de tamaño, lo que ocurra primero. Las evidencias se exportarán al terminar cada sesión para conservarlas durante el ciclo académico. Las instantáneas ayudan a revertir una VM, pero no reemplazan una copia externa cifrada.

7 Diseño de red

7.1 Segmentación y direccionamiento

OPNsense será el único equipo conectado a todas las redes internas. Cada proxy tendrá una interfaz en la DMZ y app-lab una en la red de aplicaciones. La red de gestión aloja únicamente la interfaz gráfica (GUI) de OPNsense; la administración de proxies y app-lab se realizará por SSH desde la VPN mediante reglas específicas, sin añadir interfaces de gestión a esas VM, para no crear rutas alternativas. La separación de funciones y la protección de servicios internos orientan el diseño, sin asumir confianza por ubicación (Lakhno et al., 2022).

Las redes internas de VirtualBox cumplen en el laboratorio la función de las VLAN: cada una forma un dominio de difusión aislado y solo se comunica con las demás a través de OPNsense. La Tabla 7 resume el direccionamiento de cada zona y el identificador de VLAN 802.1Q que le correspondería en una implantación con switch administrable.

Tabla 7

Plan de direccionamiento del laboratorio

Zona	VLAN equivalente	Subred y gateway	Equipos
WAN simulada de solo anfitrión	—	192.168.56.0/24	Cliente anfitrión .1; OPNsense .2; sin DHCP
DMZ interna	10	10.10.10.0/24; .1	VIP .10; proxy1 .11; proxy2 .12
Aplicaciones interna	20	10.10.20.0/24; .1	app-lab .21; contenedores dentro de esta VM
Gestión interna	40	10.10.40.0/24; .1	GUI de OPNsense
VPN enrutada	— (túnel)	10.10.60.0/24	Túnel .1; administradores .10–.49 y consulta .50–.99, asignados por certificado; sin puente a WAN

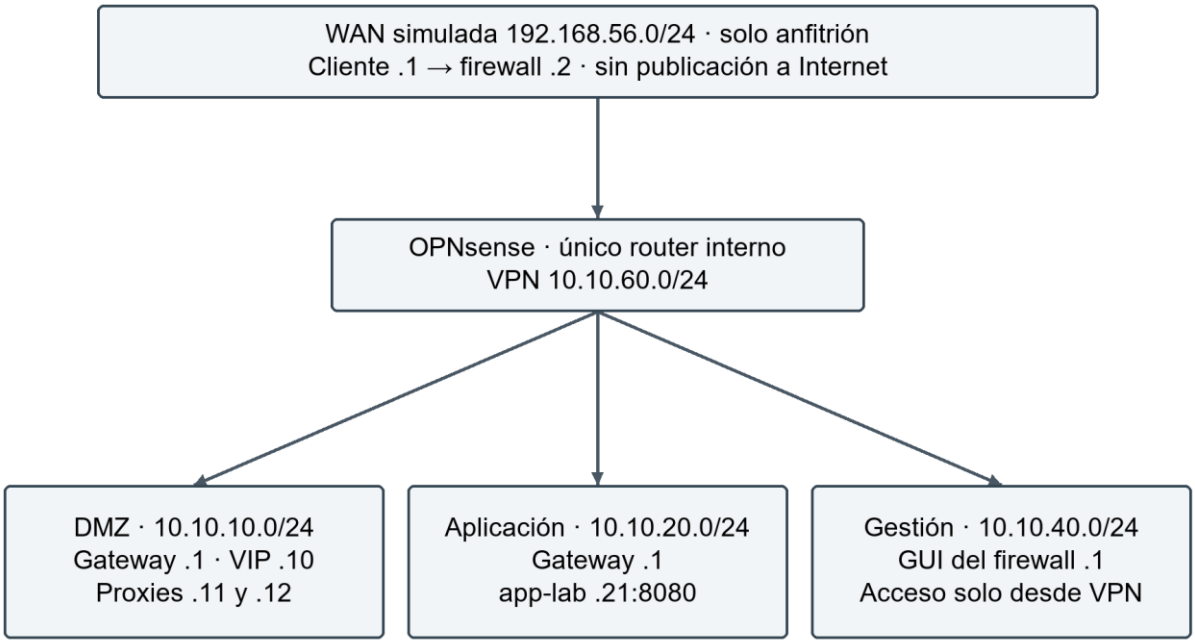
Nota. Elaboración propia. Cada gateway interno pertenece a OPNsense. Antes del montaje se verificará que estas subredes no coincidan con las del equipo anfitrión.

El nombre app.seguridad.test resolverá a 192.168.56.2 mediante el archivo hosts del cliente, y el firewall traducirá (NAT) TCP 443 hacia 10.10.10.10. Se usará un certificado emitido por una autoridad de certificación (CA) local de laboratorio, confiada únicamente por el cliente de pruebas, con nombre y cadena verificados. TCP 80 se limitará a redirigir a HTTPS. El laboratorio no requiere dominio ni certificado públicos.

La Figura 3 representa la topología de las redes virtuales y la posición de OPNsense como único enrutador interno.

Figura 3

Topología de redes virtuales aisladas



Nota. Elaboración propia. La WAN simulada permite ensayar el acceso externo sin publicar la aplicación en Internet.

7.2 Política de comunicaciones

La Tabla 8 expresa las reglas con origen, destino y propósito. Se permitirá el retorno de conexiones válidas y se denegará el resto. En la WAN privada se adaptará la opción que bloquea redes privadas para admitir solo el segmento de pruebas. Las reglas automáticas de administración se comprobarán y restringirán tras validar la VPN, manteniendo la recuperación por consola.

Tabla 8

Política mínima de firewall y hosts

ID	Origen → destino	Protocolo o servicio permitido
R1	Cliente WAN → VIP por NAT	TCP 443; TCP 80 solo redirección
R2	proxy1/proxy2 → app-lab .21	TCP 8080; ninguna otra fuente
R3	proxy1 ↔ proxy2	Protocolo IP 112 (VRRP) por unidifusión entre .11 y .12
R4	Cliente WAN → OPNsense .2	UDP 1194 para VPN con MFA
R5	VPN administradores (10.10.60.10–.49) → proxies y app-lab	TCP 22; claves SSH y permisos limitados
R6	VPN administradores (10.10.60.10–.49) → OPNsense 10.10.40.1	TCP 443 para GUI; cuenta individual
R7	VM → gateway de su red	DNS TCP/UDP 53 y NTP UDP 123, si se habilitan en el firewall
R8	VM → repositorios aprobados	TCP 443 solo durante mantenimiento; retirar antes del ensayo

ID	Origen → destino	Protocolo o servicio permitido
R9	VPN consulta (10.10.60.50–.99) → proxies	TCP 22 con cuenta sin sudo para lectura de evidencias
R10	Cualquier otro flujo	Denegar; registrar rechazos relevantes con límites

Nota. Elaboración propia. R3 circula dentro de la DMZ y se controla en ambos proxies. IP 112 es el número de protocolo de VRRP.

Docker inserta reglas propias en iptables que eluden el firewall local del host; por ello, la restricción del puerto 8080 de app-lab se aplicará en la cadena DOCKER-USER, admitiendo solo 10.10.10.11 y 10.10.10.12. Se probará desde la WAN, la VPN y un origen no autorizado. Ningún puerto de base de datos se expondrá en la VM. El anfitrión no deberá puentear ni reenviar tráfico entre redes y, durante las pruebas sin VPN, carecerá de rutas alternativas a las redes internas.

La VPN usará certificado de cliente y autenticación con contraseña más una contraseña de un solo uso basada en tiempo (TOTP). OPNsense asignará a cada cliente una dirección fija según el nombre común de su certificado, de modo que las reglas R5, R6 y R9 distinguen el perfil por la dirección de origen. OPNsense documenta el segundo factor para la VPN, pero esa protección no se extiende automáticamente a SSH ni a la consola (OPNsense, s. f.), que requieren sus propios controles. El administrador del hipervisor conserva capacidad de modificar el laboratorio, por lo que el aislamiento no protege frente a quien controla el equipo físico.

8 Diseño de seguridad

8.1 Riesgos y correspondencia de controles

La evaluación adopta la identificación, el análisis y el tratamiento de riesgos conforme a ISO/IEC 27005. Se asigna probabilidad P e impacto I de 1 a 5 y se calcula R = P × I: bajo 1–4, medio 5–9, alto 10–15 y crítico 16–25. Las valoraciones son estimaciones del escenario; el riesgo residual presupone controles implementados y se revisará tras los ensayos (International Organization for Standardization e International Electrotechnical Commission, 2022).

Los activos considerados son la VM firewall (OPNsense y VPN), los dos proxies con WAF, app-lab con sus datos sintéticos, las claves y certificados, los registros de auditoría y el repositorio de configuraciones; su criticidad se refleja en el impacto I de la Tabla 9.

La Tabla 9 vincula amenazas, medidas y responsabilidad. Se usan las categorías de NIST CSF 2.0 como referencia de resultados de gestión, sin atribuir certificación ni cumplimiento normativo (National Institute of Standards and Technology, 2024).

Tabla 9

Matriz de riesgos y controles

Riesgo	P×I inicial	Tratamiento principal y responsable	Residual	CSF 2.0
R1 SQLi/XSS	4×5=20	CRS, exclusiones mínimas, regresión; seguridad	2×5=10	PR.PS, DE.CM
R2 saturación del laboratorio	3×5=15	Límites y parada del ensayo; redes	3×5=15	PR.IR, RS.MI
R3 falla de proxy	3×4=12	VIP, salud funcional y ensayos; sistemas	1×4=4	PR.IR, RC.RP
R4 falsos positivos	3×4=12	Ajuste con tráfico legítimo; seguridad/aplicaciones	2×3=6	PR.PS, DE.AE
R5 credenciales comprometidas	3×5=15	VPN, MFA, mínimo privilegio; sistemas	2×5=10	PR.AA
R6 componentes vulnerables	3×4=12	Inventario y parches probados; sistemas	2×4=8	ID.AM, PR.PS
R7 pérdida de información	2×5=10	Copias consistentes y restauración; datos	1×5=5	PR.DS, RC.RP
R8 disco lleno por logs	3×3=9	Rotación, cuotas, alertas; operación	1×3=3	DE.CM, PR.IR
R9 falla de componentes comunes	3×4=12	Recuperación y aceptación del alcance; jefatura	3×4=12	GV.RM, PR.IR

Nota. Elaboración propia. R1, R2, R5 y R9 conservan riesgo residual alto (≥ 10) con la escala definida; la jefatura del proyecto los acepta para el alcance de laboratorio mediante un acta registrada antes de iniciar la Unidad III. En R2 los límites acotan el efecto, pero no eliminan la probabilidad de saturar el anfitrión compartido. En producción requerirían tratamiento adicional.

8.2 Protección HTTP y acceso

La documentación de CRS recomienda ajustar las exclusiones según los falsos positivos observados, y advierte que elevar el nivel de paranoia aumenta el esfuerzo de ajuste (OWASP CRS Project, s. f.). CRS se habilitará inicialmente en modo de observación con tráfico sintético representativo y luego en bloqueo PL1. Cada excepción identificará regla, ruta, parámetro, causa, responsable y caducidad, y se evitará deshabilitar familias completas para corregir un formulario. La detección se repetirá después de ajustar excepciones, siguiendo la preocupación por la pérdida de cobertura en reglas personalizadas (Floris et al., 2025; Reyes Narváez et al., 2026).

Se controlarán el tamaño de los cuerpos, los tipos de contenido, los tiempos de espera y la consistencia de las cabeceras. Las divergencias de interpretación entre frontend y backend pueden introducir *request smuggling*; el antecedente motiva revisar las cadenas HTTP y añadir casos de mensajes ambiguos, ya que CRS por sí solo no resuelve el problema (Huang et al., 2022). El tráfico entre proxy y backend usa HTTP interno en esta versión: la segmentación y los controles locales reducen la exposición, y el TLS interno queda como mejora futura que requerirá actualizar el diseño y las pruebas.

La administración usará cuentas individuales, VPN con TOTP y permisos separados para administración, seguridad y consulta. Se aplicará una política local de contraseñas de al menos 15 caracteres, con bloqueo de claves comprometidas y cambio ante evidencia de compromiso. Siguiendo la guía SP 800-63B-4, TOTP no se considera un autenticador

resistente al *phishing* (Temoshok et al., 2025). Los secretos y las claves privadas se excluyen de Git y de las capturas públicas.

8.3 Respaldo, monitoreo y recuperación

La Tabla 10 define la recuperación de configuraciones y datos sintéticos. Se conservará la copia de trabajo, una exportación en el anfitrión y otra cifrada en un medio externo. Las dos primeras comparten el mismo equipo y pueden perderse juntas; por eso la copia externa se verificará antes de ensayar restauraciones.

Tabla 10

Respaldo y recuperación del laboratorio

Activo	Mecanismo y frecuencia	RPO	RTO
Firewall, VPN y WAF	Exportación cifrada diaria y tras cada cambio aprobado	24 h	2 h
Aplicación y datos sintéticos	Exportación consistente al cierre de sesión; detener escritura o usar copia nativa de la base de datos	24 h	2 h
Registros de pruebas	Exportación al finalizar cada caso, con fecha, nodo y hash	1 caso	1 h

Nota. Elaboración propia. RPO expresa la pérdida máxima admitida; RTO se mide desde el inicio de la recuperación. Si falla la exportación de un caso, el caso se repite.

Se restaurará secuencialmente una VM o su configuración en una red aislada, reutilizando recursos, sin mantener una quinta VM. Se verificarán el acceso legítimo, un bloqueo conocido, los *hashes* y los tiempos. Las copias de la base de datos deben ser consistentes, porque copiar archivos mientras están en escritura no garantiza la recuperación.

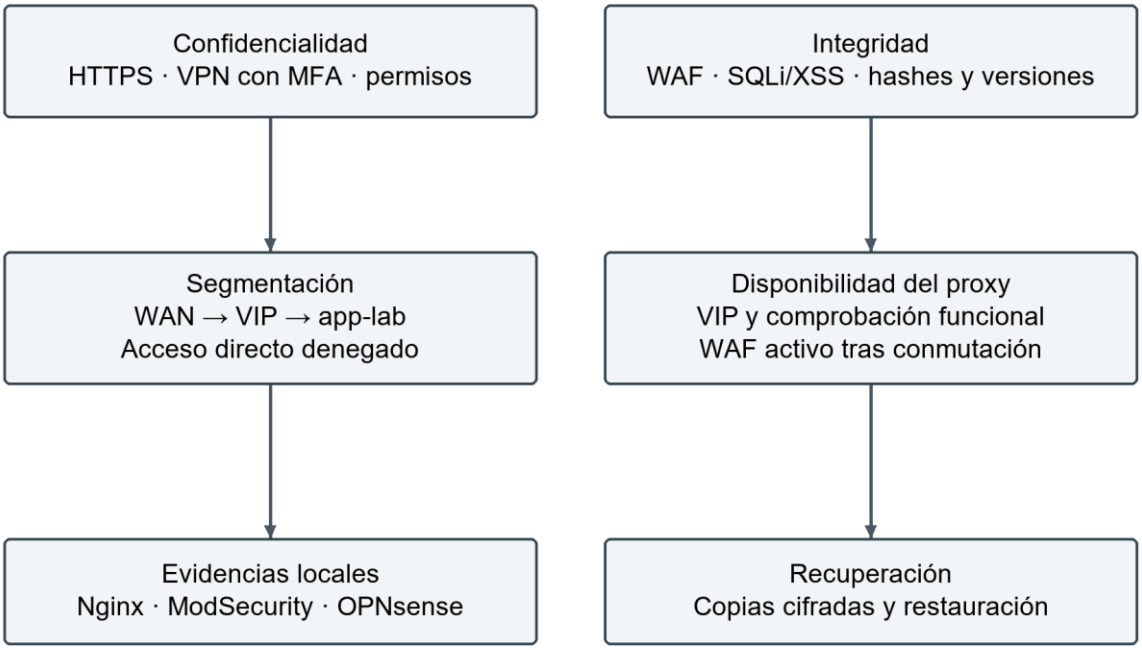
La observabilidad se apoya en la auditoría de ModSecurity, los registros de acceso y error de Nginx, los eventos de keepalived y los registros de OPNsense. Al cerrar cada prueba se exportarán a una carpeta por caso y nodo, preservando identificador, fecha, regla y resultado sin divulgar secretos. La literatura sobre sistemas de gestión de información y eventos de seguridad (SIEM) sustenta una futura centralización, que queda fuera del montaje inicial (Tuyishime et al., 2023). Las mediciones HTTP motivan vigilar las respuestas además de la CPU, sin implementar el escalado horizontal automático de *pods* (HPA) de Kubernetes (Zhou y Yong, 2024).

El cliente guardará tiempos y códigos HTTP, mientras el operador registrará CPU, RAM y espacio antes, durante y después de la prueba. El responsable revisa los eventos durante las sesiones y exporta la evidencia; el diseño no incluye monitoreo continuo ni alertas centrales automatizadas. Como control mínimo, cada proxy ejecutará un script local programado (cron) que registre el espacio libre (alerta al 20 %, ya definido), el estado de keepalived y los códigos 5xx de Nginx, para revisarlos al inicio y al cierre de cada sesión.

La Figura 4 concentra las barreras de acceso y las rutas de auditoría y recuperación. Sus controles se verificarán con PT-07 y PT-10 a PT-13.

Figura 4

Controles de seguridad y recuperación



Nota. Elaboración propia. Las copias externas se cifran y la recuperación se valida en una red aislada.

9 Diseño operativo

9.1 Responsabilidades

La Tabla 11 asigna responsabilidades a roles. J: jefatura; S: sistemas; R: redes; C: seguridad; A: aplicaciones/datos. En la matriz RACI, R ejecuta, A aprueba, C es consultado e I es informado. Cada actividad tiene un único aprobador.

Tabla 11

Asignación RACI

Actividad	J	S	R	C	A
Cambios del proxy	A	R	C	C	C
Reglas CRS y excepciones	A	C	I	R	C
Firewall y VPN	A	C	R	C	I
Respaldo y restauración	A	R	I	C	C
Pruebas funcionales y datos	A	C	I	C	R
Incidente crítico	A	R	R	R	C

Nota. Elaboración propia. En el equipo académico una persona puede asumir varios roles; se identificará quién ejecuta y quién revisa cada prueba.

9.2 Procedimientos y atención

La Tabla 12 reúne la secuencia mínima de operación y su evidencia. La atención de incidentes integra preparación, detección, respuesta y recuperación, conforme al perfil de NIST CSF 2.0 desarrollado en SP 800-61r3 (Nelson et al., 2025).

Tabla 12

Procedimientos de operación

Procedimiento	Frecuencia y ejecución	Evidencia
PO-01 cambios	Por cambio: respaldo, revisión, prueba, despliegue controlado, comprobación y reversión si falla	Ticket, diff, versión y resultados
PO-02 parches	Revisión mensual; urgencias según riesgo. Probar primero en laboratorio y nodo pasivo	Inventario, aprobación y validación
PO-03 reglas WAF	Revisión semanal y ante incidentes: identificar FP, excepción mínima y regresión	Solicitud anonimizada, regla y caducidad
PO-04 vigilancia	Revisión durante cada sesión y exportación al finalizar	Registro local, copia y acciones
PO-05 restauración	Semana 3: recuperación aislada, integridad y comparación con RPO/RTO	Tiempos, hashes y acta
PO-06 conmutación	Semanas 2 y 4 y tras cambios relevantes: nodo/servicio, retorno controlado	Línea temporal y solicitudes fallidas

Nota. Elaboración propia. Los periodos se aprobarán al inicio de la implementación.

Un cambio comenzará en el nodo pasivo, con validación sintáctica y solicitudes de regresión; luego se realizará una conmutación controlada y la actualización del otro nodo. Si fallan los criterios, se restaurará la versión anterior y se registrará el incidente. La sincronización no sobrescribirá automáticamente una configuración válida con una modificación sin verificar.

Durante las sesiones, un compromiso no previsto o la pérdida general del laboratorio obliga a detener el ensayo y aislar la VM afectada. Una falla parcial requiere diagnóstico antes de continuar, y los cambios menores se programan al cierre de la sesión. El laboratorio opera sin soporte 24/7 ni acuerdo de nivel de servicio institucional. El operador registra el incidente y el revisor autoriza la reanudación tras verificar los controles.

El analista correlacionará identificador, aplicación y regla, comprobará el caso con el responsable funcional y evitará divulgar contenido sensible. La contención debe preservar evidencias y tener un criterio de salida. Se documentarán causa, impacto, restauración y acciones preventivas; una disminución del número de alertas no demuestra por sí sola una mejora de seguridad.

10 Plan de implementación

10.1 Secuencia y dependencias

Las cuatro semanas comienzan después de aprobar el alcance, disponer del hardware y habilitar los accesos. Se verifica primero que el equipo reutilizado soporte las cuatro VM. La Tabla 13 identifica actividades, responsables y dependencias, y la Figura 5 muestra su distribución en veinte días hábiles relativos al inicio aprobado. Se estiman 80 horas de trabajo, equivalentes a unas 20 horas semanales durante cuatro semanas, además de las pruebas desatendidas.

Tabla 13

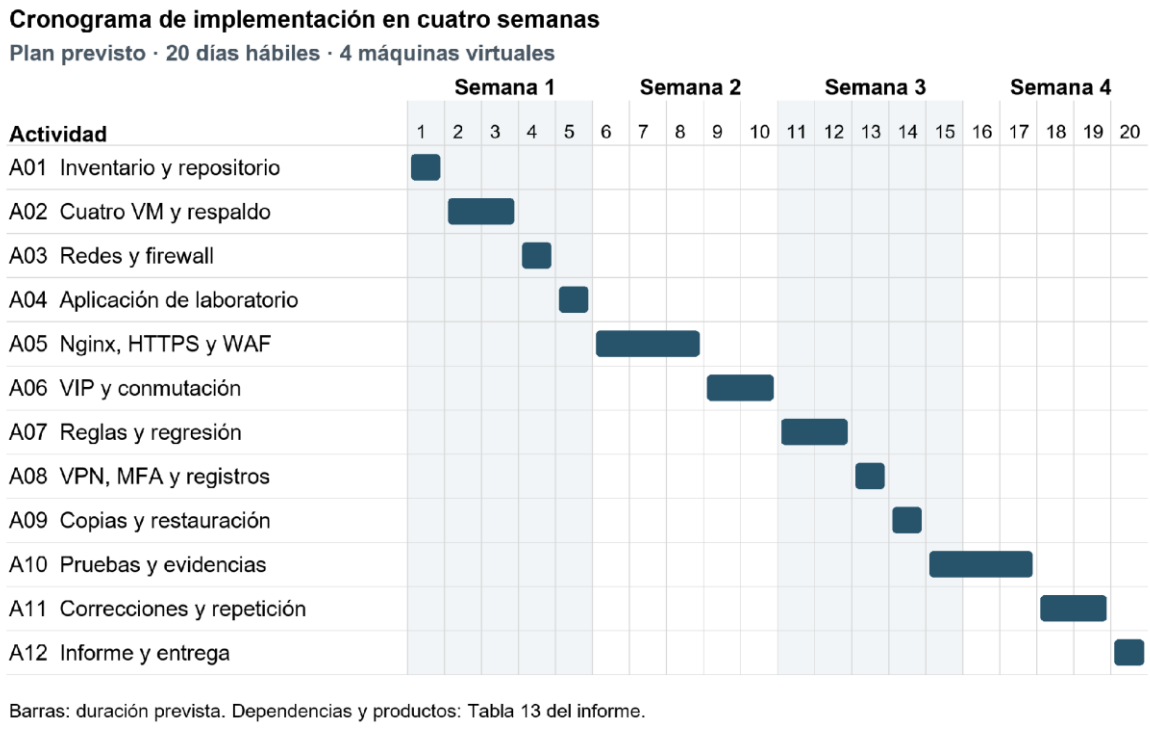
Cronograma de implementación en semanas relativas

ID	Semana	Actividad y producto	Responsable	Dependencia
A01	1	Día 1: Inventario, versiones y repositorio	S	Recursos disponibles
A02	1	Días 2–3: Cuatro VM y respaldo inicial	S	A01
A03	1	Día 4: Redes, firewall y rutas verificadas	R	A02
A04	1	Día 5: Aplicación y datos sintéticos	A	A03
A05	2	Días 6–8: Nginx, HTTPS, ModSecurity y CRS	S, C	A03
A06	2	Días 9–10: VIP, salud funcional y conmutación inicial	S	A04, A05
A07	3	Días 11–12: Ajustes PL1/PL2 y regresión	C	A04, A05
A08	3	Día 13: VPN, MFA, permisos y registros	R	A03, A05
A09	3	Día 14: Copias cifradas y restauración	S	A04
A10	3–4	Días 15–17: Pruebas integradas y evidencias	C, A	A06–A09
A11	4	Días 18–19: Correcciones y repetición de pruebas	S	A10
A12	4	Día 20: Informe, exposición y entrega de enlaces	J	A11

Nota. Elaboración propia. Los días 1–20 son hábiles relativos. Los roles corresponden a la Tabla 11. Las comprobaciones básicas se realizan desde la instalación; A10 reúne la validación formal y la semana 4 reserva dos días para corregir y repetir casos afectados.

Figura 5

Diagrama de Gantt de implementación en cuatro semanas



Nota. Elaboración propia. Las barras indican ventanas previstas. S1 comprende los días 1–5; S2, 6–10; S3, 11–15; S4, 16–20. Un retraso que agote la reserva requiere reprogramación, nunca la eliminación de pruebas de seguridad.

10.2 Control de cambios y cierre

Se consideran riesgos de ejecución la demora de equipos, la incompatibilidad del conector WAF, la saturación del generador y la falta de tráfico legítimo representativo. Cada riesgo se registrará con responsable, señal de alerta y medida: reprogramación por recursos, prueba anticipada de versiones, control del consumo del generador y revisión de recorridos de la aplicación. La cobertura de pruebas se mantiene completa aunque el plazo se ajuste.

La puesta en servicio exige configuración versionada, restauración probada, reglas revisadas, responsables designados y aceptación de riesgos residuales. Se mantendrá una ventana de reversión con respaldo y criterios de activación. La transición de observación a bloqueo se aprobará tras comprobar los recorridos de usuario y la regresión de ataques (Durmuşkaya y Bayraklı, 2025; Reyes Narváez et al., 2026).

La entrega incluye el informe en Word y PDF, los cuatro diagramas técnicos y el Gantt, además de una presentación de 10 a 15 diapositivas, configuraciones sin secretos y evidencias reproducibles. Los repositorios del proyecto se indican a continuación.

10.3 Repositorio y carpeta de entrega

Repositorio GitHub del proyecto

https://github.com/andyladera/nginx-modsecurity-ha-waf

Contiene el README de instalación, las configuraciones sin secretos, los scripts y los procedimientos de prueba. La versión final identificará el commit o la etiqueta utilizada para reproducir el laboratorio.

Carpeta de Google Drive del proyecto

https://drive.google.com/drive/folders/15zeA5zHhnOo8clLq_9IcmiTSu33IPfX1?usp=sharing

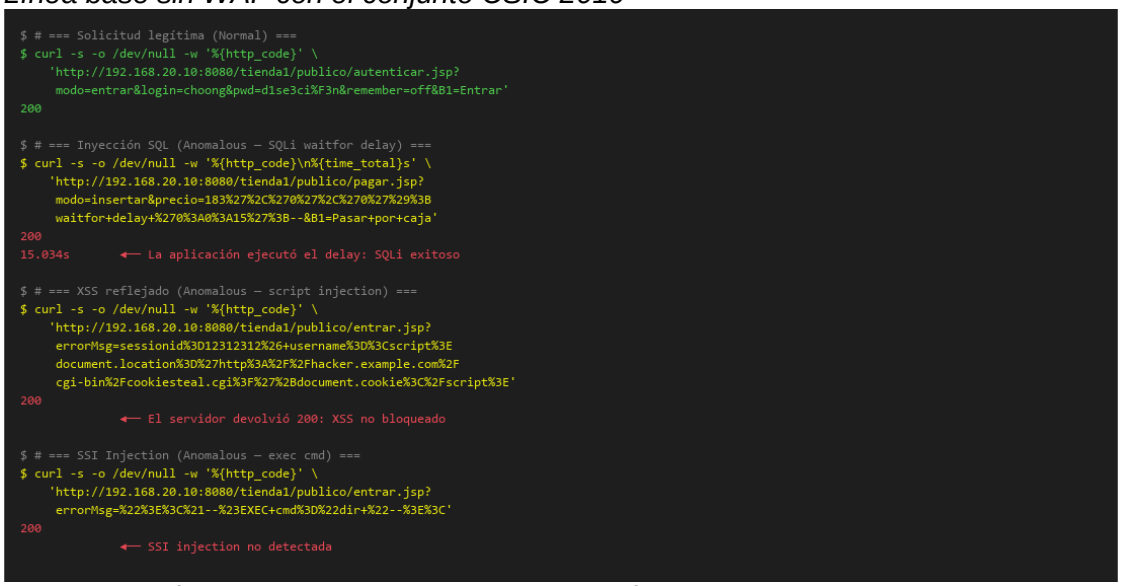
Contiene el informe, la presentación, los diagramas, las capturas y los resultados organizados por caso PT. El evaluador tendrá permiso de lectura, y cada evidencia se relacionará con su configuración y fecha.

Evidencia del prototipo mínimo. Las Figuras 6, 7 y 8 presentan las capturas del prototipo mínimo. La Figura 6 muestra la línea base sin WAF: las solicitudes anómalas del conjunto CSIC 2010 (SQLi, XSS, SSI) obtienen HTTP 200 sin ningún bloqueo, lo que indica que la aplicación sin WAF no filtró esas solicitudes. La Figura 7 muestra el bloqueo por CRS (regla 942160, PL1) de la misma solicitud SQLi con waitfor delay, con el registro de auditoría completo de ModSecurity que incluye id de regla, severidad, anomaly score y acción. La Figura 8 muestra la conmutación de keepalived: al apagar proxy1, proxy2 asume la VIP en ~1 s (apagado ordenado) y el WAF permanece activo, bloqueando la misma SQLi con HTTP 403.

Alcance de la evidencia. Las capturas corresponden a un prototipo preliminar cuyo direccionamiento (192.168.10.0/24 y 192.168.20.10), nombre (app.lab.local) y aplicación (tienda JSP del conjunto CSIC) difieren del diseño de las Tablas 6 y 7 (10.10.x.x, app.seguridad.test y Juice Shop). Se presentan como prueba de concepto de los mecanismos (bloqueo CRS y relevo de la VIP); la validación sobre el diseño final se ejecutará en la Unidad III.

Figura 6

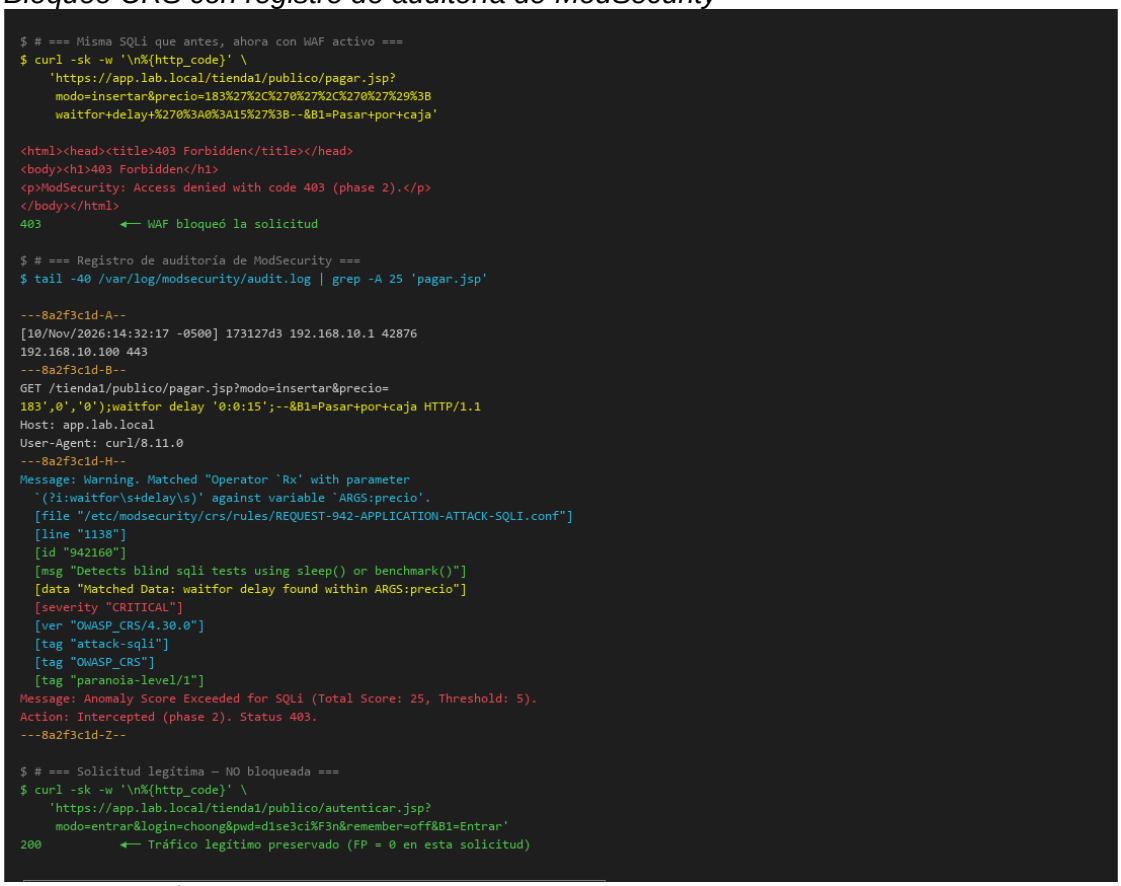
Línea base sin WAF con el conjunto CSIC 2010



Nota. Elaboración propia. Se muestran tres solicitudes anómalas representativas del conjunto HTTP CSIC 2010 (Torrano-Giménez et al., 2010): SQLi con waitfor delay, XSS con robo de cookies e inyección SSI. Sin WAF, las tres obtienen HTTP 200. La captura muestra tres solicitudes; el recuento completo de las 25 065 solicitudes sin WAF se reportará por código de estado y categoría en PT-03. Captura del prototipo preliminar (sección 10.3).

Figura 7

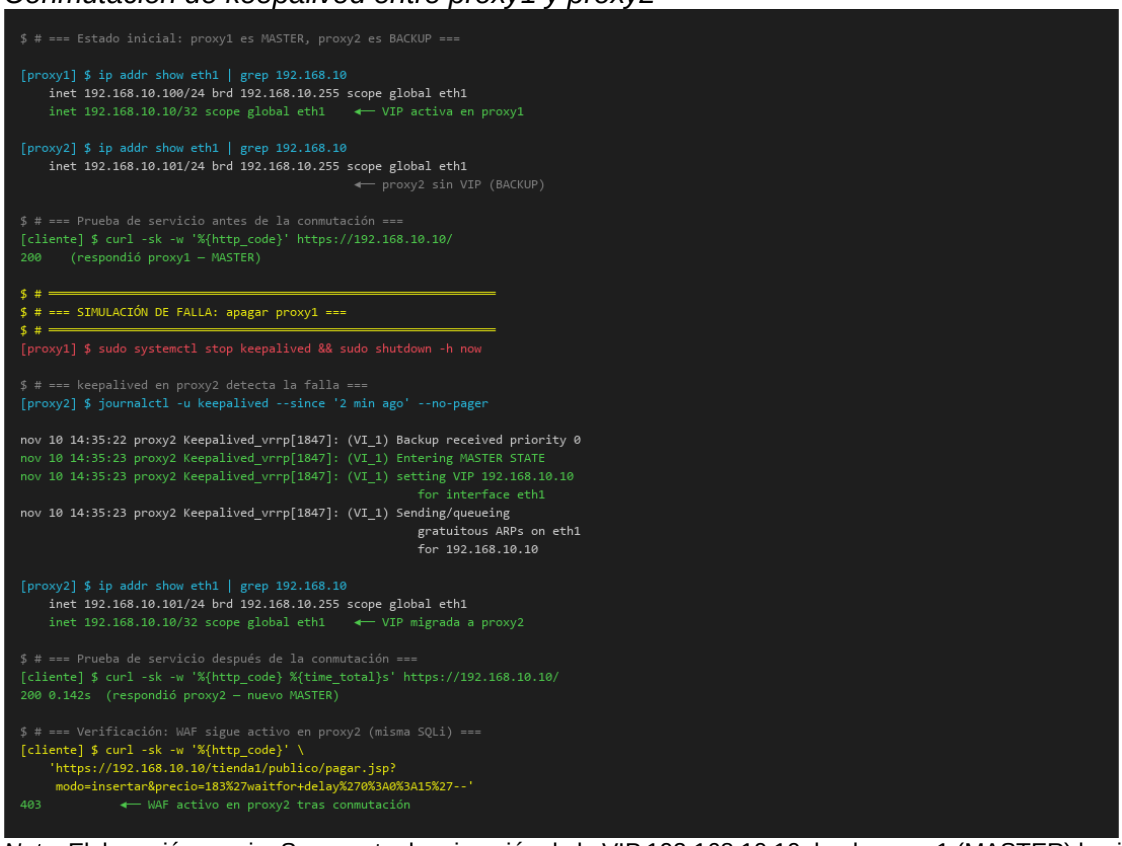
Bloqueo CRS con registro de auditoría de ModSecurity



Nota. Elaboración propia. La misma solicitud SQLi de la Figura 6 es bloqueada por la regla 942160 de OWASP CRS 4.30.0 en el nivel de paranoia 1 (PL1). El registro de auditoría muestra el id de regla, la cadena detectada (waitfor delay), la severidad CRITICAL y el anomaly score (25 > umbral 5). Una solicitud legítima posterior obtiene HTTP 200, sin bloqueo de la solicitud legítima probada (n = 1); la tasa de FP se mide en PT-03.

Figura 8

Conmutación de keepalived entre proxy1 y proxy2



Nota. Elaboración propia. Se muestra la migración de la VIP 192.168.10.10 desde proxy1 (MASTER) hacia proxy2 (BACKUP) al simular la falla de proxy1. Keepalived detecta la caída y proxy2 asume el rol MASTER en aproximadamente 1 s (< umbral de 5 s definido en RNF-02). Tras la conmutación, la misma solicitud SQLi es bloqueada con HTTP 403 por el WAF activo en proxy2. La captura muestra una ejecución con apagado ordenado del nodo; las repeticiones y el corte abrupto (apagado forzado de la VM) se miden en PT-04.

11 Plan de pruebas

11.1 Preparación y conjuntos de evaluación

El entorno registrará hardware, versiones, reglas, hash de configuraciones, red, hora sincronizada y estado de cada aplicación. Los datos serán sintéticos y las pruebas ofensivas se limitarán a destinos autorizados. Para la evaluación del WAF se utilizará el conjunto HTTP CSIC 2010 (Torrano-Giménez et al., 2010; Spangler, 2019), que proporciona 36 000 solicitudes legítimas y 25 065 anómalas con solicitudes HTTP completas (método, URL, cabeceras, cookies y cuerpo), lo que permite reproducir tráfico realista contra ModSecurity y CRS. Las categorías anómalas y su distribución por método se describen en la sección 2.1.

El tráfico legítimo cubrirá inicio de sesión, navegación, búsqueda, caracteres acentuados, cookies y los formularios disponibles en la aplicación. La clasificación multietiqueta y los estudios con URL y cabeceras refuerzan la conveniencia de separar clases y entradas, en vez de probar solo una página estática (Chindrus y Caruntu, 2025; Shaheed y Kurdy, 2022). La separación entre ajuste y evaluación y el tratamiento de variantes se justifican por los riesgos de contaminación de conjuntos y el comportamiento dependiente de la representación (Taqi et al., 2026).

El conjunto de datos de Lucz y Forstner (2025) recoge solicitudes bloqueadas por CRS en producción: aporta diversidad de eventos, aunque no es una muestra imparcial de ataques admitidos ni un conjunto legítimo. Se utilizará como recurso de inspección y regresión, tras verificar sus etiquetas, y no para estimar por sí solo sensibilidad o FP. El conjunto HTTP CSIC 2010 (Torrano-Giménez et al., 2010; Spangler, 2019) complementa este recurso al proporcionar solicitudes completas, tanto legítimas como anómalas, que se pueden enviar directamente al proxy con ModSecurity para medir la matriz de confusión (TP, FP, TN, FN) por categoría de ataque. Los marcos de generación de casos y de pruebas con aprendizaje por refuerzo (Lu et al., 2026; Sepczuk y Sosnowski, 2026) motivan incorporar variantes de evasión y registrar la cobertura alcanzada, sabiendo que el conjunto CSIC 2010 no agota todas las técnicas de evasión actuales.

11.2 Casos y aceptación

La Tabla 14 relaciona procedimiento, resultado esperado y criterio de aceptación. PT-02 comprueba un repertorio acotado de regresión y PT-03 mide la detección sobre un conjunto más amplio; el 100 % del primero no se extrapola a protección universal.

Tabla 14

Casos de prueba y trazabilidad

Caso	Procedimiento resumido	Aceptación y vínculo
PT-01	Probar nombre local, TLS, redirección y acceso directo	Nombre y certificado válidos; TLS 1.2/1.3; backend inaccesible desde la WAN; RF-01
PT-02	Reproducir ataques de regresión y correlacionar auditoría	100 % de casos curados bloqueados por el WAF; RF-02
PT-03	Evaluar legítimos/maliciosos separados del ajuste en PL1/PL2	PL1 ≥ 90 % detección, FP ≤ 2 %; PL2 meta ≥ 95 %; RF-02/RNF-04
PT-04	Apagar el proxy activo de forma ordenada y abrupta, repetir 3 veces cada una y registrar VIP y respuestas	Cada conmutación ≤ 5 s; repetir SQLi/XSS y tráfico legítimo en el respaldo; RF-03/RNF-02
PT-04b	Detener y congelar Nginx con el SO activo, 3 repeticiones por modo	Cada recuperación ≤ 5 s; RF-03/RNF-02
PT-05	Sondear 30 min con dos conmutaciones inducidas	Caída acumulada ≤ 10 s en la sesión observada; RNF-01
PT-06	Comparar 4 configuraciones con 10/50/100 usuarios	A 50: delta p95 < 50 ms y errores legítimos ≤ 1 %; a 100: errores ≤ 2 % y punto de saturación; RNF-03/05/08
PT-07	Generar bloqueos en ambos proxies; localizar y exportar cada ID	Registros correlacionables; búsqueda ≤ 5 min; copia y hash verificados; página 403 comprensible; RF-04/RNF-07/09
PT-08	Ráfagas y conexiones lentas con cliente legítimo independiente	429 y expiraciones según política; acceso legítimo conservado; RF-05
PT-09	Recargar reglas y ejecutar reversión bajo tráfico legítimo	Cero errores atribuibles al cambio; versión restaurable; RNF-06
PT-10	Intentar VPN sin factor, con factor y con rol de consulta	Acceso solo autorizado; el rol de consulta no modifica; RF-06
PT-11	Restaurar configuraciones, aplicación y datos en red aislada	Integridad y RPO/RTO de la Tabla 10; OE4

Caso	Procedimiento resumido	Aceptación y vínculo
PT-12	Ensayar la matriz de flujos permitidos/denegados y el tráfico dentro de la DMZ	Sin rutas de bypass ni administración pública; RF-01/06, OE3
PT-13	Simular incidente con detección en logs, escalamiento, contención y cierre	Cronología, responsables y acta completos; OE5/OE6

Nota. Elaboración propia. Se cuentan catorce casos porque PT-04b es independiente. Cada caso conservará entradas, resultados, fecha y evidencia.

11.3 Carga, medición y resultados

Las cuatro configuraciones son backend directo aislado, proxy TLS sin WAF, proxy TLS con PL1 y proxy TLS con PL2. Cada combinación de configuración y carga tendrá cinco minutos de calentamiento, quince de medición y tres repeticiones. Se conservarán certificados, recursos, rutas, mezcla y tamaño de respuestas. El generador se ejecutará en el anfitrión como cliente WAN y se registrarán su CPU, RAM y capacidad de emisión; como comparte recursos con las VM, puede limitar la carga, condición que se declarará y que motivará ajustar el ensayo antes de atribuir la latencia al WAF.

Los límites por IP permanecerán activos. Cuando muchos usuarios virtuales compartan IP, se documentará esa condición y se utilizará un conjunto autorizado de IP de origen para representar clientes, manteniendo el control activo. Los rechazos a solicitudes legítimas cuentan como errores. Se reportarán solicitudes por segundo, percentiles, fallos, CPU, RAM, disco, red y variabilidad entre repeticiones.

Las pruebas de reglas incorporarán codificación, mutación y campos relevantes, siempre dentro del laboratorio. Los trabajos adversariales justifican esta cobertura adicional, aunque sus tasas de evasión no predicen el comportamiento de este despliegue (Guan et al., 2023; Hemmati y Hadavi, 2022; Wu et al., 2025). Para cada resultado se conservará el número de observaciones y la matriz TP, FP, TN, FN; un rechazo del backend o del limitador de tasa no se atribuirá a detección del WAF.

La restauración se medirá desde la declaración del incidente hasta la disponibilidad funcional, incluyendo aprovisionamiento, descarga, recuperación y comprobación. La disponibilidad se calculará sobre los intervalos observados, declarando la resolución del sondeo y los errores de reloj. Un ensayo favorable no acredita disponibilidad anual ni elimina las fallas del equipo físico, del firewall o de la aplicación. Las pruebas de la Tabla 14 se ejecutarán en la Unidad III.

12 Factibilidad y costos

12.1 Alcance del presupuesto

El escenario económico corresponde a un laboratorio de cuatro semanas con un equipo ya disponible. No incluye servidores empresariales, switch administrable, NAS ni licencias comerciales. El inventario y el espacio libre deben verificarse antes de aceptar el supuesto de reutilización. Si se necesita comprar un equipo, se solicitará una cotización independiente y se sumará al escenario.

Los importes son provisiones de planificación expresadas en soles. Se separa el dinero incremental del tiempo académico valorizado. El valor contable del equipo reutilizado y su depreciación no se estiman por falta de inventario, de modo que el TCO presentado es incremental y no el costo económico completo del activo.

12.2 Inversión y operación

La Tabla 15 detalla la inversión inicial incremental del laboratorio.

Tabla 15

Inversión inicial incremental del laboratorio

Partida	Cálculo en soles	Importe	Base
Equipo anfitrión existente	Reutilización	0,00	Condicionado a inventario
Medio externo para copias	Provisión	300,00	Confirmar capacidad y precio antes de comprar
Accesorios y adecuaciones menores	Provisión	100,00	Solo si son necesarios
Preparación y documentación	60 h × 50	3 000,00	Trabajo valorizado
Subtotal económico	400 + 3 000	3 400,00	Efectivo y trabajo separados
Reserva del 10 %	3 400 × 0,10	340,00	40 sobre efectivo; 300 sobre trabajo
Inversión I0	Subtotal + reserva	3 740,00	Base del TCO incremental

Nota. Elaboración propia. El desembolso inicial provisionado es S/ 440,00; el trabajo valorizado con su reserva asciende a S/ 3 300,00.

Se prevén 100 horas de equipo encendido en las cuatro semanas, una potencia media de 0,20 kW y una tarifa supuesta de S/ 0,80/kWh, que se contrastará con el pliego tarifario vigente publicado por Osinergmin para la concesionaria local, con un factor de 1,10: energía = 0,20 × 100 × 0,80 × 1,10 = S/ 17,60. Las 60 horas de preparación y las 20 de operación corresponden a actividades distintas y no se suman nuevamente en otros conceptos. Las horas de equipo pueden incluir pruebas desatendidas. El plazo concentra el esfuerzo en 15 h semanales de preparación y documentación más 5 h semanales de operación y revisión.

La Tabla 16 resume el gasto operativo (OPEX) del ciclo de cuatro semanas.

Tabla 16

Operación de un ciclo de cuatro semanas

Partida	Hipótesis de cálculo	S/ por ciclo
Energía	0,20 kW × 100 h × 0,80 × 1,10	17,60
Operación y revisión de pruebas	20 h × S/ 25	500,00
Copia externa adicional y consumibles	Provisión del ciclo	32,00
OPEX del ciclo	Suma	549,60

Nota. Elaboración propia. El trabajo académico valorizado no implica un pago. La operación se limita al ciclo de cuatro semanas, sin guardia 24/7.

12.3 TCO y sensibilidad

El horizonte del TCO es un ciclo académico: TCO = I0 + OPEX del ciclo = 3 740,00 + 549,60 = S/ 4 289,60. En cuatro semanas no se agregan reposiciones ni valor residual. El efectivo incremental estimado, si el trabajo lo realiza el estudiante, es S/ 489,60: S/ 440,00 iniciales más S/ 49,60 de energía y consumibles. Ambos resultados presuponen un equipo existente y se refieren solo al laboratorio. La Tabla 17 muestra cómo varía el TCO ante cambios en las horas de preparación, el uso del equipo o la compra de hardware.

Tabla 17

Sensibilidad del costo del ciclo

Cambio respecto al escenario base	Efecto en TCO	TCO resultante
Base	—	S/ 4 289,60
Preparación de 40 h a S/ 50, incluida reserva	− S/ 1 100,00	S/ 3 189,60
Preparación de 80 h a S/ 50, incluida reserva	+ S/ 1 100,00	S/ 5 389,60
Equipo encendido 200 h en vez de 100	+ S/ 17,60	S/ 4 307,20
Compra de equipo por importe C	+ 1,10 × C	S/ 4 289,60 + 1,10 × C

Nota. Elaboración propia. C será un precio cotizado con impuestos; la fórmula añade la misma reserva del 10 %.

12.4 Factibilidad técnica y académica

La simplificación reduce los componentes que deben instalarse y mantenerse, mientras conserva las evidencias centrales de Seguridad de TI: inspección HTTP, segmentación, control de acceso, registro, recuperación y continuidad de la protección. El principal esfuerzo se concentra en integrar Nginx y ModSecurity, verificar que las reglas del firewall y de los contenedores impidan el acceso directo y mantener ambos WAF equivalentes.

La factibilidad es preliminar hasta confirmar recursos y ejecutar las pruebas. El beneficio se expresa como capacidad de demostrar controles y documentar sus límites; sin datos de caídas institucionales no se calculan ahorros, VAN ni retorno financiero. Una evolución a producción requerirá dimensionamiento de demanda, redundancia física, centralización de registros, soporte y un nuevo presupuesto.

12.5 Factibilidad operativa

La operación se sustenta en las 80 horas previstas para el equipo de cinco integrantes (sección 10.1 y Tabla 16), distribuidas según la matriz RACI de la Tabla 11, sin guardia 24/7 ni acuerdo de nivel de servicio. Es viable en el ciclo académico si el equipo reutilizado y los accesos están disponibles desde la semana 1; en caso contrario se reprograma el plan (sección 10.2). Los procedimientos de cambios, parches, reglas WAF, vigilancia, restauración y conmutación están definidos en la Tabla 12.

13 Conclusiones

OE1. La revisión bibliográfica aportó tres criterios que el diseño adopta: comprobar la salud del proxy por su respuesta funcional (Godinho et al., 2023), ajustar CRS con tráfico legítimo y exclusiones mínimas para controlar los falsos positivos (Reyes Narváez et al., 2025, 2026) y

evaluar con conjuntos separados que incluyan variantes de evasión. El contexto universitario se conserva como motivación, mientras la implementación se acota a una aplicación sintética de laboratorio.

OE2. Se especificaron seis RF y nueve RNF con pruebas asociadas, que cubren disponibilidad, seguridad, rendimiento, escalabilidad, mantenibilidad y usabilidad. La carga de 50 usuarios virtuales y los umbrales de detección, latencia y conmutación son metas de laboratorio pendientes de medición, distintas de la capacidad institucional.

OE3. La arquitectura se simplificó a cuatro VM en un solo equipo: OPNsense, dos proxies con WAF y app-lab, con 10 vCPU, 14 GB de RAM y 160 GB de disco. Las redes internas separan la DMZ, la aplicación y la gestión del firewall, con identificadores de VLAN equivalentes. La redundancia cubre la capa proxy, mientras el equipo físico, el firewall y la aplicación siguen siendo puntos únicos de falla.

OE4. El diseño conserva segmentación, HTTPS, VPN con MFA, permisos por rol, auditoría y recuperación. Los nueve riesgos y sus valoraciones se revisarán después de los ensayos, y R1, R2, R5 y R9 se aceptan formalmente para el alcance de laboratorio. El registro local y su exportación proporcionan evidencia académica, aunque no sustituyen una supervisión central permanente.

OE5. Las cuatro semanas y el presupuesto incremental corresponden al laboratorio reducido. El TCO estimado de S/ 4 289,60 incluye trabajo valorizado; el efectivo incremental estimado es S/ 489,60 bajo reutilización. Si se requiere hardware adicional, se cotizará y se actualizará el modelo.

OE6. Las catorce pruebas priorizan SQLi/XSS, tráfico legítimo, bloqueo de acceso directo, VPN, restauración y conmutación con el WAF activo. Los enlaces de GitHub y Drive se incorporan en la sección 10.3. La ejecución completa y la carga de evidencias corresponden a la Unidad III, y la extensión a producción queda como trabajo futuro.

14 Referencias

Alotaibi, F. M., y Vassilakis, V. G. (2023). Toward an SDN-based web application firewall: Defending against SQL injection attacks. *Future Internet, 15*(5), Artículo 170. https://doi.org/10.3390/fi15050170

Canonical. (2026). *Ubuntu Server 24.04.5 LTS installation image* [Imagen de instalación]. https://releases.ubuntu.com/24.04/

Chindrus, C., y Caruntu, C.-F. (2025). Machine learning-based multilabel classification for web application firewalls: A comparative study. *Electronics, 14*(21), Artículo 4172. https://doi.org/10.3390/electronics14214172

Coscia, A., Dentamaro, V., Galantucci, S., Maci, A., y Pirlo, G. (2024). PROGESI: A PROxy grammar to enhance web application firewall for SQL injection prevention. *IEEE Access, 12*, 107689–107703. https://doi.org/10.1109/ACCESS.2024.3438092

Costa, J., Matos, R., Araujo, J., Li, J., Choi, E., Nguyen, T. A., Lee, J.-W., y Min, D. (2023). Software aging effects on Kubernetes in container orchestration systems for digital twin cloud infrastructures of urban air mobility. *Drones, 7*(1), Artículo 35. https://doi.org/10.3390/drones7010035

Curipallo Martínez, M., Guevara-Vega, A., Reyes Narváez, A., Raura, G., y Barba Molina, H. (2025). Web application protection optimization through Coraza WAF: Performance assessment against OWASP risks in reverse proxy configurations. *Engineering Proceedings, 115*(1), Artículo 17. https://doi.org/10.3390/engproc2025115017

Dawadi, B. R., Adhikari, B., y Srivastava, D. K. (2023). Deep learning technique-enabled web application firewall for the detection of web attacks. *Sensors, 23*(4), Artículo 2073. https://doi.org/10.3390/s23042073

Demirel, D. Y., y Sandikkaya, M. T. (2023). Web based anomaly detection using zero-shot learning with CNN. *IEEE Access, 11*, 91511–91525. https://doi.org/10.1109/ACCESS.2023.3303845

de Oliveira, L. T., Vendramin, A. C. B. K., de Santi, J., y Pigatto, D. F. (2025). Analysis of computational resource consumption of an intrusion detection system based on

containerized network functions virtualization. *Journal of Internet Services and Applications, 16*(1), 683–695. https://doi.org/10.5753/jisa.2025.6112

Deshpande, K. V., y Singh, J. (2024). Weighted transformer neural network for web attack detection using request URL. *Multimedia Tools and Applications, 83*(15), 43983–44007. https://doi.org/10.1007/s11042-023-17356-9

Díaz-Verdejo, J., Muñoz-Calle, J., Estepa Alonso, A., Estepa Alonso, R., y Madinabeitia, G. (2022). On the detection capabilities of signature-based intrusion detection systems in the context of web attacks. *Applied Sciences, 12*(2), Artículo 852. https://doi.org/10.3390/app12020852

Docker. (2026). *Docker Engine version 29 release notes*. https://docs.docker.com/engine/release-notes/29/

Durmuşkaya, M. E., y Bayraklı, S. (2025). Web application firewall based on machine learning models. *PeerJ Computer Science, 11*, Artículo e2975. https://doi.org/10.7717/peerj-cs.2975

Floris, G., Scano, C., Montaruli, B., Demetrio, L., Valenza, A., Compagna, L., Ariu, D., Piras, L., Balzarotti, D., y Biggio, B. (2025). ModSec-AdvLearn: Countering adversarial SQL injections with robust machine learning. *IEEE Transactions on Information Forensics and Security, 20*, 6693–6705. https://doi.org/10.1109/TIFS.2025.3583234

Fujii, S., Kakei, S., Hirotomo, M., Takita, M., Shiraishi, Y., Mohri, M., Kuzuno, H., y Morii, M. (2025). A+Block: Web security add-on service by just pointing to your website URL. *IEICE Transactions on Information and Systems, E108.D*(8), 933–946. https://doi.org/10.1587/transinf.2024DAK0002

Godinho, A., Rosado, J., Sá, F., Caldeira, F., y Cardoso, F. (2023). Torrent poisoning protection with a reverse proxy server. *Electronics, 12*(1), Artículo 165. https://doi.org/10.3390/electronics12010165

Guan, Y., He, J., Li, T., Zhao, H., y Ma, B. (2023). SSQLi: A black-box adversarial attack method for SQL injection based on reinforcement learning. *Future Internet, 15*(4), Artículo 133. https://doi.org/10.3390/fi15040133

Han, J., y Ye, Y. (2023). Research on the application of load balancing in educational administration system. *Journal of Information Processing Systems, 19*(5), 702–712. https://doi.org/10.3745/JIPS.04.0289

Hemmati, M., y Hadavi, M. A. (2022). Bypassing web application firewalls using deep reinforcement learning. *ISeCure, 14*(2), 131–145. https://doi.org/10.22042/isecure.2022.323140.744

Huang, Q.-X., Chiu, M.-Y., Chen, Y.-F., y Sun, H.-M. (2022). Attacking websites: Detecting and preventing HTTP request smuggling attacks. *Security and Communication Networks, 2022*, Artículo 3121177. https://doi.org/10.1155/2022/3121177

International Organization for Standardization e International Electrotechnical Commission. (2022). *Information security, cybersecurity and privacy protection—Guidance on managing information security risks* (ISO/IEC 27005:2022). https://www.iso.org/standard/80585.html

Keepalived. (2026). *Keepalived* (Versión 2.4.3) [Software]. https://www.keepalived.org/download/

Lakhno, V., Blozva, A., Kasatkin, D., Chubaievskyi, V., Shestak, Y., Tyshchenko, D., y Brzhanov, R. (2022). Experimental studies of the features of using WAF to protect internal services in the zero trust structure. *Journal of Theoretical and Applied Information Technology, 100*(3), 705–721. https://www.jatit.org/volumes/Vol100No3/11Vol100No3.pdf

Lu, P., Zhong, X., Xu, W., y Wang, Y. (2026). A multi-source feedback-driven framework for generating WAF test cases. *Future Internet, 18*(3), Artículo 167. https://doi.org/10.3390/fi18030167

Lucz, G., y Forstner, B. (2025). A thirty-day dataset of malicious HTTP requests blocked by OWASP ModSecurity on a production web server. *Data, 10*(11), Artículo 186. https://doi.org/10.3390/data10110186

Ma, C., y Chi, Y. (2022). Evaluation test and improvement of load balancing algorithms of Nginx. *IEEE Access, 10*, 14311–14324. https://doi.org/10.1109/ACCESS.2022.3146422

Mauricio, L., y Rubinstein, M. (2023). A network function virtualization architecture for automatic and efficient detection and mitigation against web application malware. *Journal of Internet Services and Applications, 14*(1), 10–20. https://doi.org/10.5753/jisa.2023.2847

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Nelson, A., Rekhi, S., Souppaya, M., y Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST SP 800-61r3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

NGINX. (s. f.). *Nginx download*. Recuperado el 10 de noviembre de 2026, de https://nginx.org/en/download.html

OPNsense. (s. f.). *Two-factor authentication*. https://docs.opnsense.org/manual/two_factor.html

OPNsense. (2026). *26.7 Xenial Xenops series release notes*. https://docs.opnsense.org/releases/CE_26.7.html

Oracle. (s. f.). *Change log for Oracle VirtualBox 7.2*. Recuperado el 10 de noviembre de 2026, de https://docs.oracle.com/en/virtualization/virtualbox/7.2/relnotes/ChangeLog.html

OWASP CRS Project. (s. f.). *CRS documentation*. Recuperado el 10 de noviembre de 2026, de https://coreruleset.org/docs/index.print

OWASP CRS Project. (2026). *OWASP CRS* (Versión 4.30.0) [Software]. GitHub. https://github.com/coreruleset/coreruleset/releases/tag/v4.30.0

OWASP Juice Shop Project. (2026). *OWASP Juice Shop* (Versión 20.4.0) [Software]. GitHub. https://github.com/juice-shop/juice-shop/releases/tag/v20.4.0

OWASP ModSecurity Project. (2025). *ModSecurity-nginx* (Versión 1.0.4) [Software]. GitHub. https://github.com/owasp-modsecurity/ModSecurity-nginx/releases/tag/v1.0.4

OWASP ModSecurity Project. (2026). *ModSecurity* (Versión 3.0.16) [Software]. GitHub. https://github.com/owasp-modsecurity/ModSecurity/releases/tag/v3.0.16

Qu, Z., Ling, X., Wang, T., Chen, X., Ji, S., y Wu, C. (2024). AdvSQLi: Generating adversarial SQL injections against real-world WAF-as-a-service. *IEEE Transactions on Information Forensics and Security, 19*, 2623–2638. https://doi.org/10.1109/TIFS.2024.3350911

Reyes Narváez, A., Curipallo Martínez, M., y Barba Molina, H. (2026). AutoEx: A log-driven framework for automated exception rule generation in OWASP CRS-based web application firewalls. *Electronics, 15*(9), Artículo 1877. https://doi.org/10.3390/electronics15091877

Reyes Narváez, A., Curipallo Martínez, M., Reyes Narváez, E., Lara, F., Reyes Narváez, E. P., y Barba Molina, H. (2025). Evaluation framework for false positives in open-source WAFs based on OWASP CRS paranoia levels: A systematic approach for comparative measurement. *Engineering Proceedings, 115*(1), Artículo 1. https://doi.org/10.3390/engproc2025115001

Rus, A.-C., El-Hajj, M., y Sarmah, D. K. (2024). NAISS: A reverse proxy approach to mitigate MageCart's e-skimmers in e-commerce. *Computers & Security, 140*, Artículo 103797. https://doi.org/10.1016/j.cose.2024.103797

Sepczuk, M., y Sosnowski, K. (2026). Using the reinforcement learning agent to test the correctness of rule configuration in web application firewalls. *IEEE Access, 14*, 2134–2151. https://doi.org/10.1109/ACCESS.2025.3650335

Shaheed, A., y Kurdy, M. H. D. B. (2022). Web application firewall using machine learning and features engineering. *Security and Communication Networks, 2022*, Artículo 5280158. https://doi.org/10.1155/2022/5280158

Shahid, W. B., Aslam, B., Abbas, H., Khalid, S. B., y Afzal, H. (2022). An enhanced deep learning based framework for web attacks detection, mitigation and attacker profiling.

Journal of Network and Computer Applications, 198, Artículo 103270. https://doi.org/10.1016/j.jnca.2021.103270

Spangler, I. (2019). *CSIC 2010 web application attacks* [Conjunto de datos]. Kaggle. https://www.kaggle.com/datasets/ispangler/csic-2010-web-application-attacks

Tadhani, J. R., Vekariya, V., Sorathiya, V., Alshathri, S., y El-Shafai, W. (2024). Securing web applications against XSS and SQLi attacks using a novel deep learning approach. *Scientific Reports, 14*(1), Artículo 1803. https://doi.org/10.1038/s41598-023-48845-4

Taqi, A. K., Hassan, H. J., y Abdulsaheb, G. M. (2026). Risk-calibrated mitigation of XSS and SQL injection in JSON API traffic using deep learning and class-specific thresholds. *International Journal of Safety and Security Engineering, 16*(8), 1803–1814. https://doi.org/10.18280/ijsse.160811

Temoshok, D., Fenton, J., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., y Richer, J. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST SP 800-63B-4). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63b-4

Torrano-Giménez, C., Pérez-Villegas, A., y Álvarez Marañón, G. (2010). *HTTP dataset CSIC 2010* [Conjunto de datos]. Information Security Institute of CSIC (Spanish National Research Council). https://www.tic.itefi.csic.es/dataset/

Tuyishime, E., Balan, T. C., Cotfas, P. A., Cotfas, D. T., y Rekeraho, A. (2023). Enhancing cloud security—Proactive threat monitoring and detection using a SIEM-based approach. *Applied Sciences, 13*(22), Artículo 12359. https://doi.org/10.3390/app132212359

Wu, C., Chen, J., Zhu, S., Feng, W., He, K., Du, R., y Xiang, Y. (2025). WAFBooster: Automatic boosting of WAF security against mutated malicious payloads. *IEEE Transactions on Dependable and Secure Computing, 22*(2), 1118–1131. https://doi.org/10.1109/TDSC.2024.3429271

Zhou, H., y Yong, C. H. (2024). Implement HPA for Nginx service using custom metrics under Kubernetes framework. *IEEE Access, 12*, 189722–189734. https://doi.org/10.1109/ACCESS.2024.3509876